

OBJETIVO

De acuerdo con el Marco de COSO 2013, cuando la administración identifica un informe, ya sea procedente de un sistema, de una aplicación (por ejemplo: Microsoft Excel) o que haya sido creado manualmente, dentro del proceso de la información financiera, debe tener la garantía de que existe la integridad de los datos subyacentes y de que la información presentada en el mismo está completa y es precisa. Esta política busca definir cómo deben identificarse, gestionarse y controlarse los informes. Cabe señalar que es responsabilidad de los propietarios de los procesos identificar las EAE y aplicar los controles adecuados, tal como se indica en la política.

En Hilton Worldwide, los informes en los que se basan los controles SOX clave se denominan Evidencia Electrónica de Auditoría ("EAE", por sus siglas en inglés). La Compañía ha dividido la EAE en dos grupos denominados "Aplicaciones Desarrolladas por el Usuario" ("UDA", por sus siglas en inglés) e "Informes y Datos" ("RAD", por sus siglas en inglés), en función de la naturaleza de la manera en que se elabora el informe (es decir, forma manual frente a forma automatizada) y su sistema de origen (es decir, Hyperion, Excel, etc.).

RESUMEN DE LA POLÍTICA

Las EAE clave, que están sujetas a esta política, se definen como UDA o RAD que se utilizan para admitir las actividades clave de información financiera señaladas dentro de los controles SOX clave.

A medida que se identifican las EAE clave, éstas deben incluirse en el inventario centralizado que mantiene la Oficina de Gestión de Proyectos de SOX (SOX PMO, por sus siglas en inglés) y deben identificarse e implementarse los controles adecuados para garantizar que la información pertinente esté completa y sea precisa, así como la integridad de cualquier lógica subyacente.

ANTECEDENTES / ALCANCE

La eficacia de las actividades clave de información financiera depende de la integridad de la EAE que admite la actividad. Por lo tanto, los controles sobre la fiabilidad de las EAE son fundamentales para respaldar la integridad del proceso de información financiera de la Compañía. En consecuencia, la administración debe identificar y aplicar los controles adecuados sobre las EAE.

Los Propietarios de los Procesos deben considerar los siguientes factores cualitativos a la hora de determinar si una EAE es clave y está sujeta a esta política:

¿La EAE admite un control SOX clave?

- Ejemplos:
 - EAE admite el monto de un asiento de diario, codificación, etc.
 - La EAE admite la revelación del monto en las notas al pie o en otros informes externos
 - EAE admite la integridad y exactitud de otro informe utilizado como parte de un control SOX
 - El control SOX clave no podría realizarse (de forma fácil o suficiente) sin la EAE

Aplicaciones Desarrolladas por el Usuario (UDA)

Las UDA consisten principalmente en hojas de cálculo de MS Excel desarrolladas de manera interna, bases de datos de MS Access u otras herramientas o aplicaciones de bases de datos de escritorio (por ejemplo: herramientas de consulta/informes) creadas y mantenidas por los Propietarios de los Procesos.

- Ejemplos:
 - Uso de una tabla en MS Excel para calcular el monto de un asiento de diario (por ejemplo: una tabla en MS Excel que calcule la reserva de cuentas por cobrar necesaria en función de la antigüedad de las cuentas por cobrar)
 - Modelo de MS Excel utilizado para realizar un análisis que tendría un efecto sobre la información financiera (por ejemplo: modelo de MS Excel utilizado para realizar un análisis de deterioro)

Informes y Datos (RAD)

Los RAD son informes y datos que, por lo general, se obtienen directamente de los sistemas de la Compañía (es decir, son generados por el sistema) o compilados a partir de diversas fuentes de datos (es decir, son compilados manualmente).

Los RAD generados por el sistema se generan de una de dos maneras:

- 1) Informes estándar/predeterminados de un sistema empresarial (es decir, un sistema gestionado por TI y sujeto a Controles Generales de TI) mediante lo cual la codificación/lógica del informe no se puede alterar
- 2) Informes personalizados generados desde un sistema

Algunos ejemplos de RAD son:

- Informe estándar: Un informe detallado del Libro Mayor de Activos Fijos elaborado en PeopleSoft y que un Propietario de los Procesos utiliza a fin de respaldar un control SOX clave
- Informe de sistema personalizado: Un Informe de Cambio de Nómina que un Propietario de los Procesos utiliza a fin de admitir un control SOX clave

Nota: Una consulta en el sistema o la aplicación puede extraer los datos de la fuente y presentarlos como una tabla de Excel. En este caso, si los datos de la tabla de Excel se modifican y se utilizan para admitir un control SOX clave, el informe se considera una UDA.

APLICABILIDAD

Esta política se aplica a todos los miembros del equipo de Hoteles Corporativos, Propios y Arrendados, responsables de mantener las EAE clave que afectan los estados financieros o la información revelada en las notas al pie de la Compañía.

Esta política no aplica a las EAE que se utilizan para mantener actividades que no son parte integral de un proceso SOX o un control SOX clave.

EXCLUSIONES/EXCEPCIONES

Ninguna

DETALLES DE LA POLÍTICA

Los Propietarios de los Procesos son responsables de identificar las EAE clave dentro de sus respectivas áreas de proceso y de aplicar los controles adecuados para garantizar que haya integridad en la lógica y que los datos contenidos pertinentes en las EAE estén completos y sean precisos. Los requisitos de control para RAD y UDA varían dada la naturaleza en la que se crean y mantienen estos tipos de EAE. Los requisitos de control para cada EAE dependen de su clasificación (UDA o RAD), de la cobertura SOX para RAD (dentro o fuera del alcance) y del nivel de prioridad (tal como se indica a continuación).

Asignación de prioridad

Una vez que un RAD o una UDA se identifica como una EAE clave, se evalúa para determinar su prioridad. La prioridad de las EAE se basa en dos criterios generales que luego se dividen en seis subcriterios. Estas categorías son las siguientes:

- 1) Significación:
 - 1) *Proximidad a datos financieros*: Qué tan directo es el efecto que tiene la EAE sobre una partida o revelación de información de los estados financieros
 - 2) *Importancia relativa*: El valor en dólares del efecto que una EAE puede tener en una partida o revelación de información de los estados financieros
- 2) Probabilidad de error:
 - 1) *Frecuencia de uso*: Con qué frecuencia se utiliza la EAE para realizar un control SOX clave
 - 2) *Frecuencia de cambios en la lógica*: Con qué frecuencia se cambia la codificación o la lógica de EAE
 - 3) *Complejidad*: El nivel de sofisticación asociado con la información y los cálculos dentro de la EAE (es decir, macros y fórmulas)
 - 4) *Volumen de datos y transacciones*: El volumen de datos procesados por la EAE

A partir de las respuestas a los criterios anteriores, se determinan las clasificaciones de riesgo y se ponderan para obtener una "Puntuación de Prioridad" general para cada EAE en una escala del 0 al 9.

Las puntuaciones asociadas reflejan el riesgo general asociado con la EAE (0 - Más bajo, 9 - Más alto). Los niveles de riesgo y las puntuaciones asociadas son los siguientes:

- *Alto*: Puntuación superior a 4.99
- *Medio*: Puntuaciones que se encuentran entre 3.00 y 4.99
- *Bajo*: Puntuaciones de 2.99 e inferiores

Nota: Véase el Apéndice A: Detalles sobre la Asignación de Prioridad para una tabla que hace una referencia cruzada de los Criterios con las Respuestas y las Puntuaciones de Riesgo asociadas.

Aplicabilidad de controles

En función del nivel de riesgo final de cada EAE, la siguiente tabla destaca los controles asociados de los que son responsables los Propietarios de los Procesos:

	Alto	Medio	Bajo
Informes y datos (Sistemas SOX basados en TI) <i>Informes o datos generados a partir de sistemas con Controles Generales de TI eficaces</i>	➤ Controles automatizados <i>Nota: No se requiere ninguna acción del Propietario del Proceso más allá de la ejecución del control manual para el que se produce la EAE</i>	➤ Controles automatizados <i>Nota: No se requiere ninguna acción del Propietario del Proceso más allá de la ejecución del control manual para el que se produce la EAE</i>	Según sea necesario para validar el motivo de su uso en el control <i>Nota: No validado por AI</i>
Informes y datos (Sistemas SOX no basados en TI) <i>Informes o datos generados a partir de sistemas sin Controles Generales de TI eficaces (o no comprobados)</i>	➤ Totalidad y exactitud ➤ Integridad y lógica	➤ Totalidad y exactitud ➤ Integridad y lógica	Según sea necesario para validar el motivo de su uso en el control <i>Nota: No validado por AI</i>
UDA <i>Aplicaciones desarrolladas por el usuario (por ejemplo: hojas de cálculo, bases de datos de MS Access)</i>	➤ Restricción del acceso ➤ Revisión del acceso ➤ Distinción entre diferentes versiones ➤ Revisión de cambios ➤ Integridad y lógica ➤ Totalidad y exactitud ➤ Copias de seguridad	➤ Restricción del acceso ➤ Revisión del acceso ➤ Integridad y lógica ➤ Totalidad y exactitud	Según sea necesario para validar [texto ilegible]

RESPONSABILIDADES

- Propietario del Proceso:
Eficacia de controles (c/ evidencia relacionada)
- AI/ Auditoría externa:
Verificación de eficacia de controles

Definiciones de controles

- **Totalidad y exactitud:** Cada vez que se utiliza una EAE, se revisa/verifica que la información contenida en ella se encuentre en su totalidad y sea exacta (por ejemplo: conciliación de totales de control del sistema origen con respecto a EAE).
- **Integridad y lógica:** Cada vez que se utiliza una EAE, se revisa la lógica central, la codificación (por ejemplo: fórmulas, parámetros) y la estructura (por ejemplo: referencias a fuentes de datos) de la EAE.
- **Restricción del acceso:** El acceso a la EAE está restringido mediante la protección con contraseña a nivel de archivo o mediante su almacenamiento en una unidad compartida de acceso controlado (o similar, como un sitio de MS SharePoint)
- **Revisión del acceso:** El acceso a las ubicaciones de las unidades compartidas (o similares) se revisa por lo menos una vez al año para comprobar su idoneidad
- **Distinción entre diferentes versiones:** Se utilizan convenciones de nomenclatura para distinguir claramente la versión vigente de la EAE
- **Revisión de cambios:** Se revisan y aprueban los cambios significativos aplicados a la lógica o la codificación de la EAE
- **Copias de seguridad:** Las EAE se almacenan en una unidad compartida o en un sitio de SharePoint (que Dell / TI respaldan)

Para facilitar el cumplimiento con los requisitos de documentación para estos controles, se proporciona una hoja de presentación *opcional* y el documento "Pruebas de EAE - Orientación para el Propietario del Proceso" dentro de la sección Documentos, herramientas y plantillas relacionados de esta política. La hoja de presentación opcional debe utilizarse para documentar los requisitos de control de cada EAE, como la restricción del acceso, la revisión de cambios y la verificación de que la información esté completa y sea precisa. Independientemente de si se utiliza o no la hoja de presentación *opcional*, el propietario del proceso o control es responsable de mantener las pruebas de que se han realizado los controles correspondientes y las revisiones relacionadas. Al hacer constar la revisión, se necesita más de una firma para hacerlo; la evidencia de la revisión debe ser clara en cuanto a lo que ésta abarcó (por ejemplo: lo que el revisor observó). El documento "Pruebas de EAE - Orientación para el Propietario del Proceso" ofrece información adicional sobre los requisitos de control y las evidencias apropiadas; sin embargo, los propietarios de los procesos deben tener en cuenta que el mantenimiento de evidencias de revisión adecuadas dependerá a menudo de la naturaleza del control, por lo que puede ser necesario que realicen una evaluación caso por caso para cumplir con la política.

DEFINICIONES

Término / Acrónimo	Definición
--------------------	------------

Miembros del Equipo de Hoteles Corporativos, Propios y Arrendados	Los Miembros del Equipo de Hoteles Corporativos, Propios y Arrendados incluyen a los miembros del equipo de todas las oficinas corporativas y regionales y de ubicaciones en hoteles propios y arrendados.
Propietarios de los Procesos	Los Propietarios de los Procesos son responsables del diseño y la eficacia operativa de los controles internos dentro de un área de procesos que afecta la presentación de información financiera.

FUNCIONES Y RESPONSABILIDADES

Entidad / Personal	Responsabilidades
Propietario del Proceso	- Documentar y mantener un inventario completo y preciso de las EAE clave - Revisar el inventario de EAE clave por lo menos cada trimestre y notificar SOX PMO sobre cualquier actualización - Garantizar que las actividades de control se apliquen, diseñen, documenten y pongan en funcionamiento eficazmente
SOX PMO	- Mantener el inventario de EAE y facilitar la actualización del inventario anual, como parte de las revisiones y actualizaciones anuales del proceso SOX - Evaluar periódicamente el diseño, la aplicación y la eficacia de funcionamiento de los controles sobre las EAE
Propietario de la Política	- Ser propietario de esta política y de los documentos, herramientas y plantillas relacionados - En caso de tener alguna pregunta, dirigirse a SOX_PMO@Hilton.com. <i>Este correo electrónico es la dirección de contacto de SOX PMO. Favor de dirigir cualquier pregunta sobre la interpretación o implementación de esta política al correo electrónico indicado.</i>

DOCUMENTOS, HERRAMIENTAS Y PLANTILLAS RELACIONADOS

Herramientas / Plantillas	Ubicación
Hoja de presentación opcional	 Hilton - EAE Cover Sheet.xlsx
Orientación para el Propietario del Proceso:	 EAE Testing Process Owner Guidance.pdf

APÉNDICE A: DETALLES PARA LA ASIGNACIÓN DE PRIORIDAD

Sección	Criterios	Definición	Respuestas	Puntuación
Significación	Proximidad a datos financieros	Una representación de qué tan directo es el efecto que tiene la EAE sobre los estados financieros y partidas.	Nivel 1 - Efecto directo en el estado financiero	9
			Nivel 2 - Efecto indirecto en el estado financiero	3
			Nivel 3 - Efecto mínimo en el estado financiero	1
	Importancia relativa	El valor en dólares del efecto que una EAE puede tener sobre un estado financiero	Alto - Efecto superior a 40M	9
			Medio - Efecto entre 20M y 40M	3
			Bajo - Efecto inferior a 20M	1
Probabilidad de error	Frecuencia de uso	¿Con qué frecuencia se utiliza la EAE para producir información / cifras?	Diario	0
			Semanalmente	1
			Mensualmente	2
			Trimestralmente	3
			Anualmente	5
			Según sea necesario	9
	Frecuencia de cambios en la lógica	La frecuencia con la que cambian la estructura o las fórmulas dentro de la EAE	Diario	9
			Semanalmente	5
			Mensualmente	3
			Trimestralmente	2
			Semestralmente	1
			Anualmente	1
			Según sea necesario	3
	Complejidad	El nivel de complejidad y sofisticación asociado con la información y los cálculos de la EAE	Alto - Extracción de datos externos, macros, etc.	9
			Medio - Traduce y reformatea	3
			Bajo - Registro o calculadora simple	1
	Volumen de datos y transacciones	La cantidad de datos y transacciones que procesa la EAE	Alto	9
			Medio	3
			Bajo	1

Los criterios anteriores se promedian para llegar a una puntuación de prioridad calculada, y proximidad a datos financieros presentó una ponderación 20% mayor que los demás criterios. Las EAE cuyas puntuaciones sean de 5 o superiores se consideran altas, las puntuaciones entre 3 y 5 se consideran medias y las puntuaciones inferiores a 3 se consideran bajas. Dentro del inventario, existe la opción de anular la puntuación de prioridad calculada con la provisión de la justificación suficiente.